

The Bank That Went Quiet

A Consumer Investigation of the Bank of Baroda Data Breach — and What India’s Silence Teaches Us

CashlessConsumer Research Desk

August 2026

Contents

1 A Bank’s Filing Cabinets, Opened to the Street	4
2 The Shape of the Haul: Why “Documents” Change Everything	4
3 The Actor: A Fast Brand with a Publication Habit	5
4 The Likely Way In: A Door Left Unlocked	6
5 The Blast Radius: What “Compromise” Actually Means for a Customer	6
6 The Silence: India’s Breach Playbook on Trial	8
7 What the World Does That India Doesn’t	10
8 The Report’s Spine: An Institutional Post-Mortem India Never Writes	10
9 What Should Happen Next	11
10 Source Register	12
11 A Note on Method: How We Got Here Without Touching the Files	13

Contact: cashlessconsumerin@gmail.com | **Companion technical report:** referenced in Appendix A. | **Freedom of Information ethics:** this report analyses systems and institutions, never victims. No customer record, file name, or leaked document is reproduced.

EXECUTIVE SUMMARY

On 24 July 2026, a ransomware group calling itself **Triple X** added Bank of Baroda — India’s second-largest public-sector bank — to its public “wall of shame”, claiming it had stolen roughly **700 gigabytes to a terabyte** of internal records. Within a day, an anonymous website on the **Tor network** appeared, letting anyone with the right software browse the alleged haul folder by folder, without a password, without a gate.

The defining fact is not the theft. It is the silence. One month later, the bank has issued no substantive public statement, has made no customer-notification programme visible, and no regulator — neither the Reserve Bank of India nor CERT-In — has published a root cause, a remediation outline, or even a confirmation. On the record, India’s second-largest state bank is behaving as though one of the largest document-infrastructure exfiltrations in Indian financial history never happened.

What appears to have been taken is different in kind from earlier Indian leaks. Dominos India, Air India and Upstox lost *database tables* — lists of customers. This time the pattern points at **whole-of-document capture**: shared drives and document repositories holding the bank’s own security audits, KYC files, compliance policies, and operational paperwork — the working filesystem of the institution itself, including its defences. An identity is stolen once; a defensive blueprint, once leaked, is gone forever.

Why the quiet matters to every account holder: a bank that will not say what was taken, how, or to whom cannot tell you whether *your* identity anchor is now in circulation. India has no public way to check. The community tools that exist for Western breaches — the “have I been pwned” exposure checks — do not support Aadhaar or PAN numbers.

This report documents the incident, the actor, the likely path in, the risk surface, and the institutional response — and it measures India’s breach-playbook against the world’s. It is written from the public record alone: no stolen file was opened, no victim’s document was read. The central finding is that India’s *silence* is not an accident. It is a doctrine — one that protects institutions, abandons consumers, and is, fortunately, still changeable.

Key Statistics & Facts:

- **700 GB - 1 TB** of internal data claimed exfiltrated from Bank of Baroda
- **24-36 hours:** time between the public extortion claim and the appearance of a browsable dump site
- **~30 days** of public silence from bank and regulators (as of 24 Aug 2026)
- **No encryption reported** — pure extortion-by-publication, matching a sector trend where data-only extortion rose from **~2% to ~22%** of incident-response cases

- **Third-party intel points to a single compromised employee credential** — an identity-perimeter failure, the same class GAO documented at Equifax
- **No customer-notification programme, no published root cause, no RBI/CERT-In forensic disclosure** observable as of writing
- India has **no public breach post-mortem institution, no identifier-level exposure check, and no safe harbour** for the security researchers whose disclosures power investigations like this one

1 A Bank's Filing Cabinets, Opened to the Street

Begin with the most serious data breach allegation ever levelled at an Indian public-sector bank, and the first thing to notice is how *ordinary* the mechanics are — and how loud the silence that followed.

On the morning of 24 July 2026, the leak site operated by the group calling itself **Triple X** listed Bank of Baroda. The claim attached to the listing was enormous: somewhere between 700 gigabytes and a terabyte of “internal data” — legal documents, customer information, business records, vendor agreements, security audits, and, by the catalogue's own shape, the bank's defensive documentation. The usual ransomware theatrics — countdown timers, victim chat rooms, sample previews behind paywalls — were absent. Within a day, a **Tor onion service** hosting a recursively browsable directory tree of the alleged haul came online and stayed reachable. On a network designed to obstruct takedowns, the material is unlikely to go away.

A month on, the record remains in the space the industry calls “**the unknown incident**”: a synchronised, disciplined corporate silence. “No core banking impact” — the only signal the bank has allowed to surface, and that through media rather than its own channels — tells a worried account holder almost nothing. It addresses the wrong fear (transaction integrity) while saying nothing about the real one (identity spill). This is the central fact of the affair, and it does more work than any single technical detail: **a bank that will not describe the breach cannot be trusted to have contained it.**

The purpose of this report is to be the public second opinion that the institutions have declined to provide. It is not a dump-and-tell exercise. It is an *institutional* autopsy — a look at the machinery of Indian cyber-governance as revealed by one of its most serious tests.

2 The Shape of the Haul: Why “Documents” Change Everything

To understand why this breach is categorically different from earlier Indian financial leaks, consider what India has been through before. In 2021, a string of famous breaches — Dominos India, Air India's passenger systems, Upstox — were, at their core, **table exports**: large structured lists of *records*. Customer names, contact details, sometimes card data. Painful, embarrassing, often re-sold. But each was a snapshot of a database.

What the BoB pattern suggests is a different animal: **the whole shared filesystem of the institution**. Document repositories, shared drives, the accumulated paperwork of years — every KYC file, every internal audit, every compliance memorandum, every security self-assessment, sitting on domain-joined shares reachable from any valid employee session. This is the difference between someone stealing your *contacts book* and someone stealing your *entire desk, cabinet and archive*.

The distinction is not pedantic. It changes three things:

1. **What is at risk.** A database leak exposes the people in the database. A document leak exposes the people *and* the institution — including the institution’s own knowledge of its weaknesses. An attacker or buyer holding the bank’s internal security documentation holds a roadmap to the bank.
2. **How the damage unfolds.** Records age; a two-year-old KYC snapshot is stale. Documents age slower, and security audits age slowest of all. The value curve of a document dump persists for years.
3. **What “remediation” even means.** You can reset a leaked password list. You cannot un-publish a leaked defensive architecture. You must rebuild the controls it documents, on the assumption that an adversary has studied them.

This is why the report treats the *shape* of the haul — deduced from public listing metadata, never from file contents — as a first-order finding in its own right, and why the phrase used throughout is *content-agnostic*: the risk is legible from the shape of the archive even without opening a single document.

3 The Actor: A Fast Brand with a Publication Habit

Triple X is new by name and suspiciously fast by behaviour. First observed in May 2026, it had, within roughly ten weeks, listed **two state-owned banks in emerging markets** — Bank Negara Indonesia (about two terabytes claimed) and now Bank of Baroda. Ransomware trackers indexed it in June 2026. These are not the hallmarks of a start-up.

Three signature behaviours distinguish the outfit and matter for how the public should understand the BoB incident:

It publishes in full, fast. Within 24 to 36 hours of the claim, a browsable archive was live. Many extortion groups publish *samples* and negotiate; this group treats publication as the product. That is closer to a data-broker strategy wearing a ransomware brand than to classic double extortion.

It makes everything publicly readable. The dump tree was unauthenticated and recursively browsable — meaning no buyer channel gates access, and anybody, including resellers and fraudsters, can walk the aisles. Frictionless publication maximises reputational damage to the victim and — as public indexing completes — enables the resale markets.

It may not even need encryption. No encryptor sample has surfaced, and no encryption was reported for BoB. The “extortion-first” model demands no malware in the traditional sense: steal, threaten to publish, publish. Triple X sits at the frontier of a sector shift in which data-only extortion went from about 2 percent to about 22 percent of incident-response cases in a single year in industry telemetry.

The open question — one the public record cannot yet answer — is whether Triple X is a genuinely new crew or an **experienced team that rebranded**. The emergence-to-two-bank speed is more consistent with the latter. The test would be technical (encryptor binary lineage, negotiator phrasing, affiliate recruitment posts), and no sample has been surfaced publicly to run it.

4 The Likely Way In: A Door Left Unlocked

Because the stolen corpus has not been forensically published, no one outside the bank can say with certainty how the intrusion began. But the third-party intelligence that has surfaced — relayed in the security press and attributed to a vendor called GalaxyWarden — points in a specific and mundane direction: **a compromised employee email account, likely through a weak or harvested credential.**

Journallistically, the interest here is not the technique but what it implies about *what failed*. If initial access was one employee's credential, then the institution's material failure was not "ransomware defence." It was **identity hygiene**: the universal coverage of multi-factor authentication, the decommissioning of legacy authentication pathways, the habit of parking years of KYC, audit and security documentation on domain-joined shares reachable from any valid session, and the sheer federated sprawl of a public-sector bank.

A national bank is not one building. It is thousands of branches, each an endpoint, each a potential way in. The public signal points to compromise around regional geographies before central exposure — the pattern of an attacker walking the federated estate until the perimeter gave way at its weakest joint. For an institution counting its surface in branches, **a remediation plan that stops at head office is theatre.**

The broader point carries an uncomfortable historical echo. When the United States Government Accountability Office published its post-mortem of the 2017 Equifax breach, the root causes it identified were not novel malware and not sophisticated nation-state tradecraft. They were identification, detection, segmentation, and data-governance failures — the unglamorous plumbing. A breached employee credential into a document-rich estate has the same signature. The most expensive lessons of Western breaches were about *hygiene*, and India is being invited to re-learn them in public.

5 The Blast Radius: What "Compromise" Actually Means for a Customer

Without enumerating what was taken — content-agnostic by design — the risk to an ordinary account holder decomposes into a set of ugly categories, each with its own timescale and its own answer to "is this fixable?"

Risk plane	What it means in practice	Horizon	Can the customer do anything?
Identity anchors	Government ID numbers act as non-resettable secrets — you cannot change your Aadhaar, your PAN, your biometrics. Once in circulation, they are in criminal circulation for life.	Years-decades	Not mitigable; only monitorable
Authentication material	Any credentials or password hashes present enable “stuffing” attacks — automated attempts to reuse them across other services — and onward resale.	Weeks-months	Resettable <i>if</i> enumerated; archived copies persist
Meta-compromise	The bank’s own security documentation, if taken, becomes an offensive roadmap for future attackers, and audit trails reveal past control gaps.	Months-years	Out of the customer’s hands; requires institutional control overhaul
Human layer	Named employees and customers become targets of precisely crafted social-engineering campaigns that sound plausible because the sender knows who you are.	Immediate	Out-of-band verification; staff briefings

Risk plane	What it means in practice	Horizon	Can the customer do anything?
International exposure	Bank of Baroda operates across multiple foreign jurisdictions. If overseas-entity records were in the captured estate, foreign regulators' notification clocks — GDPR-style duties — may run independently of India's inaction.	Quarters	Legal review per jurisdiction; a foreign regulator may act before India does

A necessary dose of honesty belongs here. Research by RUSI, built from interviews with ransomware victims, found that in practice the *systematic exploitation of leaked personal data for fraud* is less common than the volume of leaked data would suggest — the extortion itself is the business, not the resale. But that average is sector-neutral. **A bank's holdings are not average:** they are dense with identity anchors and authentication material, the two categories with the longest and least-resettable tails. For a bank, the base rate should be treated as a floor, not a comfort.

For the customer, the arithmetic is bleakly simple. The one thing you most want from a breached institution — “*was I in the haul?*” — is precisely the thing this bank has not offered, and which India has no public tool to answer. It is a documented, decades-long tail of *not knowing*.

6 The Silence: India's Breach Playbook on Trial

The most informative comparison for the BoB affair is not another bank breach; it is India's own track record of responding to mega-breaches. Lay the cases side by side and a doctrine emerges.

Jurisdiction / breach	State response	Published root cause?	Consumer remedy
USA — Equifax 2017	Congressional investigation, GAO audit, DOJ indictments, FTC/CFPB consent order (~\$700M settlement)	Yes — GAO + House report	Credit monitoring, settlement fund

Jurisdiction / breach	State response	Published root cause?	Consumer remedy
Australia — Optus / Medibank 2022	Joint Cyber Taskforce, legislation within weeks, privacy-regulator proceedings	Partial — agency statements	Class actions, passport/ID replacement drives
India — Aadhaar portal 2018	FIR lodged against the journalist who reported it; access quietly restricted	No	None
India — CoWIN 2023	Denial (“reflection, not a breach”), bot takedowns, PIB fact-checks	No	None
India — ICMR 2023 (~815M records alleged)	Silence; CBI probe signalled, never publicly concluded	No	None
India — Bank of Baroda 2026	Silence; only “no core banking impact” via media	No	None

Read down the Indian column and the pattern is unambiguous: **shoot the messenger, deny the event, publish nothing.** The Aadhaar/Tribune episode is the founding trauma — a journalist reporting a claimed exposure of Aadhaar data was booked under cheating, forgery, and cyber-law sections, triggering national press-freedom condemnation and a measurable chilling effect on the entire researcher community. Every subsequent Indian institution has internalised the lesson: *silence is safe, disclosure is dangerous.* Bank of Baroda’s month of quiet is not an oversight; it is the PSU-banking expression of that doctrine.

Three of those six rows are financial or identity infrastructure meant to serve the same ordinary customer the report speaks to. None published a root cause. None offered a real consumer remedy. The customers of India’s mega-breaches — in six years and across a payment giant’s customer base, a citizens’ identity database, the national vaccination record, and now a second-largest state bank — have collectively received **no post-mortem, no exposure check, and no compensation mechanism** from the institutions involved.

That makes the public-record asymmetry worth stating plainly. **SEBI forces listed companies to disclose material events; RBI imposes no equivalent transparency obligation on banks for a breach.** A listed fintech must tell the market about an outage; a bank can sit silent about a megabreach. That asymmetry is a regulatory *choice*, and it is changeable by a circular tomorrow morning.

7 What the World Does That India Doesn't

The comparative record of large breaches is not all gloom; it is also a menu of responses that have actually worked elsewhere, and which India's community could adopt even while institutions stay silent.

Notification infrastructure. In the West, the de-facto check-my-exposure utility is Have I Been Pwned (HIBP), which ingests mega-breaches, applies honest *verified/unverified* flags, and lets individuals check in privacy. Its discipline of marking datasets unverified — as it did for National Public Data — became the honest middle path between alarm and dismissal that neither victims nor regulators always supplied. India has no HIBP-equivalent supporting Aadhaar, PAN, or mobile numbers. Building a hashed-lookup exposure service for Indian identifiers is, today, the single highest-value community intervention available for BoB customers — and nobody is doing it.

Curated custodianship. Distributed Denial of Secrets demonstrates the lawful-middle custodianship model: verified datasets, journalist-first access, refusal of gratuitously harmful material. The opposite pole — raw BreachForums-style dumping — repeatedly gets the ecosystem seized and relaunched. An Indian consortium following the ICIJ model could divide the analytical labour (consumer-harm, procurement, international-operations stories) across newsrooms without any participant holding a single customer record.

Litigation as arithmetic. The Australian data (Optus, Medibank) shows the direct legislative consequence of citizen pressure: within weeks, penalties were raised from a token A\$2.22 million to a formula that can reach A\$50 million, three times the benefit, or thirty percent of turnover — plus a direct right of action. America converted Equifax and Capital One breaches into balance-sheet reality through settlements in the hundreds of millions. India's DPDP Act 2023 carries a headline penalty ceiling (up to ₹250 crore) — but it is untested, its adjudication machinery is still being constituted, and no certified class-action machinery for privacy harm exists for ordinary customers to use. **Expect the BoB remedy gap to be filled by nothing unless someone files first.**

Community self-help that worked. After Optus, community guides organised licence and passport replacement queues. After Medibank, professional bodies coordinated mental-health-sector warnings. After National Public Data, HIBP's unverified-flag communication gave people an honest way to calibrate alarm. The BoB translation is: a plain-language customer action guide in English, Hindi and regional languages; an exposure-check tool for Indian identifiers; a standing RTI campaign to force the "was CERT-In notified within six hours?" question; and — already running — automated monitoring for reappearance of the dump.

8 The Report's Spine: An Institutional Post-Mortem India Never Writes

Hold the BoB affair up against the intellectual infrastructure that exists in the West, and the difference is stark. The GAO produced a public post-mortem of Equifax. The

US House Oversight Committee concluded the breach was “entirely preventable” and traced the technical failure to an *organisational* cause — a security chief reporting outside the technology chain, creating what it called an “accountability gap.” Academics built teaching case studies of Equifax and Capital One. Economists modelled why paying ransoms is systemically corrosive. Threat vendors built schoolbook accounts of the ransomware economy.

India’s independent research tradition on its own breaches is real but thin — and tellingly, the largest-scale findings have come from *foreign* vendors (the US firm Resecurity surfaced the alleged 815-million-record ICMR/Aadhaar-correlated exposure) and from individual researchers working without legal protection (the responsible-disclosure work on Aadhaar and government fingerprint leakage; the researcher who reported fourteen Indian government vulnerabilities). The inference is uncomfortable: **civil society is doing the forensic paperwork that Indian institutions should own — and it is doing it without safe harbour, in the shadow of the Aadhaar-FIR precedent.**

What has never been produced is the **Indian GAO-style public post-mortem**: a published root cause, a parliamentary testimony record, a quantified consumer-harm accounting. Every ingredient exists — the RTI Act, the Comptroller and Auditor General, parliamentary committees, an active security-research community. The missing piece is institutional *demand*. This report — and the technical companion behind it — is written in that gap, as a civil-society substitute for, and an invitation to, the official process that has not yet begun.

9 What Should Happen Next

[A1] 1. **A public, dated statement from Bank of Baroda** — what was taken in category terms, which customer classes are affected, and what the bank is doing for each. A bank that names the categories without releasing documents can inform the public without compounding the harm. 2. **A root-cause disclosure from RBI and CERT-In.** The ~6-hour incident-reporting duty under CERT-In Directions (April 2022) makes the “was it reported on time?” question testable by RTI — and it should be tested. 3. **An identifier-level exposure-check tool** for Indian customers, built by the community if institutions will not build it. 4. **A consumer remedy pathway.** Until India’s privacy and consumer-protection apparatus matures, the realistic lever is the Consumer Protection Act’s unfair-trade-practice route — theoretically aggregable, practically unbroken ground, awaiting its first filer. 5. **A regulatory rebalancing:** a breach-transparency circular from RBI, so that banks face the same material-event disclosure duty SEBI already imposes on listed companies. 6. **A safe harbour for researchers.** Until responsible disclosure is legally protected, India will keep shooting the messengers whose disclosures are its only source of truth.

10 Source Register

This report is built from the public record and from the companion technical report (Documents/research/bob-breach-technical-report.md), which documents classes of evidence and confidence levels for every claim. Key public ingredients relied on:

BoB incident record: Triple X leak-site claims as relayed by ransomware trackers; WatchGuard tracker indexing; GalaxyWarden-attributed weak-credential reporting in the security press; independent metadata-only crawl of the onion service (methodology described in the companion report).

Comparative breach literature: GAO-18-559 (Equifax); US House Oversight Committee Equifax report; HBS Case 118-031; MIT (Neto & Madnick) Capital One case study; INFORMS ISRE “Extortionality”; Zscaler and Vectra double-extortion telemetry; RUSI ransomware-harms occasional paper.

India precedent record: Resecurity ICMR advisory (via The Hindu); The Wire’s Aadhaar/CoWIN/ICMR response chronicles; UIDAI-vs-Tribune FIR record (CSO Online, MediaNama, India Today, Livemint); Dark Reading coverage of Indian government-vulnerability disclosures.

Comparative response record: FTC/CFPB Equifax settlement materials; Clifford Chance, Allens, BAL Lawyers, Wotton Kearney analyses of Optus/Medibank class actions and Privacy Act amendments; HIBP breach pages.

11 A Note on Method: How We Got Here Without Touching the Files

A note on what this report does and does not contain. The authors did not open, download, or read any file from the leaked archive. Every original figure and claim in this report rests on four classes of public evidence: what the attacker *claimed*; observable *metadata* about the infrastructure (that the site existed and was browsable), never its contents; the *official* record (regulatory obligations, statutory duties); and *independent* reporting by security vendors and press. This discipline has a cost — we cannot give affected-customer counts or enumerate document classes beyond what public claims assert — and a purpose: it keeps the report citeable by a regulator, a bank director, or another researcher who has never touched the corpus. The point of the rule is not inconvenience; it is that the institution’s silence should not be answered with irresponsibility. Systems are the object of analysis. Victims are not the object of repetition.

ANNEXURES — EXPLAINED LIKE YOU'RE FIVE (ELI5)

The following annexures set the jargon aside. They are written for the account holder, the parent, the pensioner — the person this breach is actually about.

Annexure A. What actually happened, in plain words

Imagine the largest building on the street is a bank. Inside, in long, unlocked corridors, sit filing cabinets that hold not just money records but *everything the bank has ever written down*: who owes what, who works here, how the building's security is designed, where the weak spots are, memos between departments, years of paperwork.

Now imagine somebody found a single forgotten door left unlocked — maybe because one employee's password was weak and got figured out. One unlocked door does not sound dramatic. But behind it, every filing cabinet in the building was within reach, and the visitor spent a long time copying as much as they could carry.

That copying is the breach. The bank noticed (or didn't), and then the visitors set up a street stall where anyone who wanted could walk past and look at the copies. The bank's response so far has mostly been to keep its doors closed and not say anything to the neighbours — even though the neighbours are the ones in the copies.

That is it. No magic. No extraordinary technology. An unlocked door, a very large building, and a very quiet aftermath.

Annexure B. The cast of characters

- **Bank of Baroda** — the second-largest state-run bank in India, and the one whose files are said to have been copied.
- **Triple X** — the group doing the claiming and the publishing. New name, but very fast, which makes people suspect they may have done this before under another name.
- **CERT-In** — India's national cybersecurity watchdog, the agency that is supposed to be told about computer incidents, usually within hours. Whether it was told here is a question nobody has answered.
- **RBI (Reserve Bank of India)** — the central bank, the regulator who supervises how banks behave. It has published nothing about this.
- **The Tor network** — a privacy tool that hides where a website is hosted. It is why the "street stall" cannot simply be shut down by unplugging one computer.
- **DPDP Act 2023** — India's privacy law, which is *supposed* to require a bank to tell affected people about a breach. It has done none of that here.
- **You** — the account holder, the person at the end of all of this, and the one the whole system is supposed to protect.

Annexure C. Could this touch my life? The “why should I care” page

This is a fair question, so here is the honest answer, using a schoolhouse picture.

School picture. When you enrol at a school, they take your photo, your address, your signature. That card is *you* on paper. Suppose the school’s loose-leaf binder with everyone’s cards gets copied. Your photo and address are those copies. The problem: you cannot get a *new face*. You cannot change your birth date. Some of what was copied is simply permanent about you.

For a bank, the “school card” is your ID number, your linked accounts, the documents you submitted to open the account. If those are in the copies, they are now in circulation, and unlike a leaking bucket you cannot easily replace your own identity. This is why breaches are not just about money — they are about *identity anchors*, the permanent facts about you that no password change fixes.

The honest qualifications. Not every copied document harms its owner. Most of the fear in these events is blunter than the actual harm, and many things in a bank’s files are dull records nobody acts on. But the categories of *identity anchors* and *authentication material* are precisely the ones that never expire. A bank’s files are denser in these than almost anything else on the internet. So: it is reasonable to be alert — and unreasonable to be told nothing and expected to stay calm.

Annexure D. What should you do today? (practical steps)

No panic required — but a short list of sensible, mostly free steps. Think of it as locking your own windows while the landlord sorts out the building.

1. **Change the important passwords.** Especially the one for internet banking and any email that can reset it. Make them long; a sentence is better than a single word. Do not reuse the banking password anywhere else.
2. **Turn on two-step verification** for internet banking and for your main email. This is the single cheapest lock you own, and it is exactly the kind of lock the attacker got past to enter the bank.
3. **Watch your linked numbers.** Banks rarely call asking for OTPs or passwords; if someone calls *you* and sounds like they already know your name, your branch, your recent transactions, treat it as suspicious and hang up. Call the official number on the back of your card instead.
4. **Check your statements.** Look at recent transactions; report anything you did not make to the bank immediately and in writing. Many banks refund unauthorised transactions when reported promptly.
5. **Do not pay to "verify."** A genuine program will never ask for money or an OTP to confirm whether you are affected.
6. **If the bank ever offers a credit-freeze or monitoring option, take it.** It costs them little and gives you early warning.
7. **Push for the country-level fixes** in Annexure E — one email to your bank, one RTI, one complaint — because the individual steps only help so much when the institution stays silent.

Annexure E. A tiny glossary

- **Breach / leak** — someone outside took a copy of data they should not have.
- **Extortion** — holding that copy and threatening to reveal it unless paid.
- **Ransomware** — software that locks your files until you pay. Here, notably, none was reported — the group's weapon is the *threat of exposure* itself.
- **Identity anchor** — a fact about you that cannot be changed (ID number, date of birth, biometrics). Once leaked, it stays leaked.
- **Authentication / credentials** — the passwords, one-time codes, and tokens that prove you are you. These *can* be changed — the tragedy is when institutions do not tell you to.
- **Stuffing attack** — criminals trying a stolen password against many other websites, betting you reused it.
- **Tor** — the privacy network that makes the leaked archive hard to remove.
- **RTI (Right to Information)** — India's tool for forcing institutions to answer questions. It is the ordinary citizen's best legal lever here.
- **DPDP Act** — India's data-protection law, still settling into force, that is meant to compel breach notification.

Annexure F. The big picture, in one sentence per question

- **Was my money stolen?** Not necessarily. "Data copied" is not the same as "cash moved." That is why banking services mostly kept working.
- **Was my identity copied?** Possibly. Only the bank knows — and chooses not to say. That is the whole problem.
- **Can I fix it if it was?** Your passwords, yes. Your permanent facts, no — only watching and careful behaviour.
- **Why won't they tell me?** Because disclosure has historically been punished in India, and silence has been safe. That is a doctrine, and doctrines can be changed.
- **What would a better world do?** Tell everyone what was taken, let anyone check their own exposure for free, hold the institution publicly accountable for how it happened, and give affected people a way to be made whole. All of that exists in western countries; all of it is missing here — and none of it is impossible.
- **What can one person do?** Use the practical steps in Annexure D, ask the questions in Annexure G, and file the first complaint. The institutions change when the first file is filed.

Annexure G. Three questions worth asking out loud (and by RTI)

These are the consumer's legitimate questions, phrased so an ordinary citizen can ask them of the institutions — by email, by complaint, and by Right to Information where applicable.

1. **To Bank of Baroda:** "Was my account data part of the July 2026 data exposure, and what exactly are you doing for the customers who were affected?"
2. **To CERT-In / MeitY:** "Was a six-hour incident report received from Bank of Baroda between 20 and 31 July 2026 regarding this breach?"
3. **To the RBI:** "What supervisory action, if any, has been initiated in connection with the July 2026 incident at Bank of Baroda, and will the findings be published?"

Ask them. Institutions that operate in silence depend on nobody asking. The entire point of this report is that somebody should.

Prepared by the CashlessConsumer Research Desk. This report contains no customer records and no reproduced leaked documents. It is offered as a public document in the spirit of open data and the lawful right to information.

"The philosophers have only interpreted the world; the point is to change it."